

Clase 234 — Logging y detección en la nube

Parte: **10 — Seguridad en la nube y contenedores** · Fuente: *AWS CloudTrail / Azure Monitor / Google Cloud Logging docs y MITRE ATT&CK for Cloud* 🕒 Duración estimada: **120 min** · Nivel: **Intermedio**

🎯 Objetivo

Construir la capa de visibilidad que hace posible detectar y, más tarde, responder a incidentes en la nube. El alumno aprenderá qué logs existen (plano de gestión, red, datos), cómo centralizarlos de forma inmutable, y cómo escribir detecciones basadas en amenazas reales mapeadas a MITRE ATT&CK for Cloud (creación anómala de claves, deshabilitar logging, exfiltración, etc.).

📊 Resultados de aprendizaje

Al finalizar, el alumno podrá:

1. **Identificar** las fuentes de log clave en cada nube y qué registran.
2. **Centralizar** logs de forma inmutable y con retención adecuada.
3. **Escribir** reglas de detección para técnicas de MITRE ATT&CK for Cloud.
4. **Integrar** los logs con un SIEM (Sentinel, Security Lake, Chronicle).
5. **Evitar** puntos ciegos (logging deshabilitado, regiones sin cobertura).

📖 Temas

#	Tema	Por qué importa
1	Tipos de log: gestión, red, datos	Cada uno cubre una capa distinta
2	CloudTrail / Activity Log / Cloud Audit Logs	El "quién hizo qué" de la API
3	Flow logs y logs de DNS	Movimiento lateral y C2
4	Centralización inmutable	Un atacante intentará borrar rastros
5	Detecciones y reglas	Convertir logs en alertas útiles
6	SIEM en la nube	Correlación y respuesta
7	Puntos ciegos comunes	Logging desactivado o incompleto

📖 Definiciones y características

- **Log del plano de gestión:** registra llamadas a la API (CloudTrail, Activity Log, Cloud Audit Logs). *Clave:* la fuente forense número uno en la nube.
- **Flow logs:** metadatos de conexiones de red. *Clave:* detectan movimiento lateral y exfiltración.
- **Data events:** acceso a datos (p. ej. GetObject de S3). *Clave:* costosos pero clave para detectar exfiltración de datos.

- **Log immutable:** almacenamiento append-only, protegido contra borrado. *Clave:* preserva la evidencia frente a un atacante con acceso.
- **Detección:** regla que convierte patrones de log en alerta. *Clave:* debe mapearse a técnicas de ATT&CK.
- **SIEM:** plataforma de correlación y alerta (Sentinel, Security Lake+OpenSearch, Chronicle). *Clave:* una múltiples fuentes.
- **Punto ciego:** actividad sin registro. *Clave:* regiones o cuentas sin logging son terreno libre para el atacante.

Herramientas y preparación

- Logging del proveedor activado: **CloudTrail** (multi-región), **VPC Flow Logs**, **Azure Monitor/Activity Log**, **Google Cloud Audit Logs**.
- Un destino centralizado (bucket dedicado + SIEM); **Sigma** para escribir reglas portables.
- Opcional: **Athena/Log Analytics/BigQuery** para consultar logs.

```
# Buscar en CloudTrail eventos de creación de claves de acceso IAM
aws cloudtrail lookup-events \
  --lookup-attributes AttributeKey=EventName,AttributeValue=CreateAccessKey
# Consultar Google Cloud Audit Logs por acciones de un principal
gcloud logging read 'protoPayload.authenticationInfo.principalEmail="user@dom.com"' --limit 2
```

Laboratorio guiado

1. Verifica que el logging del plano de gestión está activo **multi-región** y que su bucket/almacén es immutable (object lock / retención).
2. Genera actividad en tu cuenta de laboratorio (crea una clave de acceso, abre un security group, sube un objeto) para producir eventos.
3. Escribe consultas para detectar: (a) creación de claves de acceso IAM, (b) intento de **deshabilitar CloudTrail/logging**, (c) **PutBucketPolicy** que abre un bucket.
4. Traduce esas detecciones a **reglas Sigma** y mapéalas a técnicas de MITRE ATT&CK for Cloud (Defense Evasion: *Impair Defenses*; Persistence: *Create Account/Access Key*).
5. Integra los logs en un SIEM (Sentinel/Security Lake/Chronicle) y crea una alerta que dispare al deshabilitar el logging.
6. Simula un **punto ciego**: crea un recurso en una región sin logging y comprueba que no aparece; corrige activando cobertura global.
7. Documenta la latencia entre la acción y la alerta, y ajusta la retención según requisitos de cumplimiento.

Ejercicios

1. Escribe una regla que alerte cuando se deshabilita el logging del plano de gestión.
2. Detecta un pico anómalo de **GetObject** (posible exfiltración) usando data events.
3. Crea una regla Sigma para el uso de credenciales desde una geolocalización inusual.
4. Diseña un esquema de centralización de logs multi-cuenta immutable.
5. Consulta Flow Logs para identificar una conexión saliente sospechosa.
6. Define la política de retención de logs para un requisito de 1 año.

Reto verificable

Configura la capa de visibilidad de una cuenta de laboratorio y demuestra una detección de extremo a extremo: una acción maliciosa simulada genera un evento que dispara una alerta en el SIEM.

Criterio de aceptación: el logging del plano de gestión está activo multi-región y en almacén inmutable; al ejecutar la acción simulada (p. ej. crear una clave de acceso o intentar deshabilitar el logging) se genera una alerta trazable en el SIEM, con la técnica ATT&CK asociada documentada.

Errores comunes

Síntoma / mensaje	Causa y cómo arreglar
No hay logs de una región	CloudTrail no multi-región; actívalo globalmente.
Atacante borró los logs	Bucket sin inmutabilidad; aplica object lock y cuenta de logging separada.
Alertas por todo (ruido)	Reglas sin afinar; ajusta umbrales y usa listas de excepción justificadas.
No se registran accesos a datos	Data events desactivados por coste; actívalos en buckets críticos.
Alertas llegan tarde	Latencia de entrega/consulta; usa entrega casi en tiempo real y consultas eficientes.

Preguntas frecuentes

? ¿Qué log activo primero si solo puedo activar uno? El del plano de gestión (CloudTrail / Activity Log / Cloud Audit Logs). Registra el "quién hizo qué" a nivel de API y es la fuente más valiosa tanto para detección como para forense.

? ¿Por qué guardar los logs en una cuenta separada e inmutable? Porque un atacante con acceso a la cuenta intentará borrar los rastros. Enviar los logs a una cuenta de logging aparte, append-only y con retención, preserva la evidencia aunque la cuenta original se comprometa.

? ¿Los data events valen la pena si cuestan más? En recursos críticos (buckets con datos sensibles) sí: son la única forma de detectar exfiltración de datos a nivel de objeto. Actívalos selectivamente donde el riesgo lo justifique, no en todo.

Referencias

- AWS CloudTrail docs. <https://docs.aws.amazon.com/awscloudtrail/latest/userguide/>
- MITRE ATT&CK — Cloud (Impair Defenses, Exfiltration). <https://attack.mitre.org/matrices/enterprise/cloud/>
- Azure Monitor & Activity Log. <https://learn.microsoft.com/azure/azure-monitor/>
- Google Cloud Audit Logs. <https://cloud.google.com/logging/docs/audit>
- Sigma — Generic signature format. <https://github.com/SigmaHQ/sigma>

Siguiente clase

[Clase 235 - Respuesta a incidentes en la nube](#)